Федеральное государственное автономное образовательное
учреждение высшего образования «Национальный
исследовательский университет ИТМО»

Информационная безопасность

Работа № 1

«Разработка защищенного REST API с интеграцией в CI/CD»

Вильданов Ильнур Наилевич

Группа: P3412

2026

Выполнение

Ссылка на GitHub

github.com/h3ywh4t/information-security-lab-1

Текст файла README.md

Информационная безопасность

Лабораторная работа № 1. REST API для личных заметок.

Стек и запуск

Java 17, Maven, Javalin 7, SQLite, bcrypt, JWT и OWASP Java Encoder. Для запуска нужны JDK 17 и Maven 3.9+:

```
export JWT_SECRET="$(openssl rand -base64 48)"
mvn compile exec:java
```

Сервер: `127.0.0.1:7070`, база `notes.db` создается автоматически. Порт и базу можно задать через `PORT` и `DATABASE_URL`. Секрет читается из окружения и не сохраняется приложением. При повторном запуске нужно задать прежний `JWT_SECRET`, иначе старые токены перестанут работать.

API

Запросы и ответы передаются в JSON.

`POST /auth/register` — регистрация (201); занятый логин — 409.

```
curl -i localhost:7070/auth/register \
  -H 'Content-Type: application/json' \
  -d '{"login":"student","password":"Correct password 123!"}'
```

`POST /auth/login` — вход (200). Ответ содержит `accessToken`, `tokenType` и `expiresIn` (900 секунд). Неверный логин или пароль — 401.

```
curl -s localhost:7070/auth/login \
  -H 'Content-Type: application/json' \
  -d '{"login":"student","password":"Correct password 123!"}'
```

Скопируйте `accessToken` из ответа в `TOKEN`. `POST /api/data` добавляет свою заметку и возвращает ее `id` и `text` (201). `GET /api/data` возвращает до 100 своих последних заметок (200).

```
TOKEN='<accessToken>'
curl -i localhost:7070/api/data \
  -H "Authorization: Bearer $TOKEN" \
  -H 'Content-Type: application/json' -d '{"text":"Первая заметка"}'
curl -i localhost:7070/api/data -H "Authorization: Bearer $TOKEN"
```

Логин: 3–32 латинские буквы, цифры, `_`, `.`, `-`. Пароль: от 12 символов, до 72 байт UTF-8. Текст: 1–2000 символов. Неверный ввод — 400, Content-Type — 415, тело свыше 16 КиБ — 413. Без JWT оба метода `/api/data` возвращают 401.

Меры защиты

SQLi: значения передаются в `PreparedStatement` через `?`, `setString` и `setLong`, поэтому не меняют SQL-запрос. Заметки выбираются по ID владельца из JWT.

XSS: `Encode.forHtmlContent` экранирует текст: `<script>` становится `<script>`. JSON-ответы имеют `nosniff` и CSP `default-src 'none'; frame-ancestors 'none'`. На клиенте следует использовать `textContent`.

JWT подписан HS256 и действует 15 минут. Middleware для `/api/*` проверяет подпись, issuer `secure-notes`, audience `notes-api`, ID в `sub`, время `iat` и `exp`. `JWT_SECRET` задается через окружение (от 32 байт). `Cache-Control: no-store` запрещает кеширование.

Пароли хешируются bcrypt с cost 12 и случайной солью. В базе хранится только хеш. Неизвестный логин проверяется с фиктивным хешем; ошибка входа одинаковая. Пароли и хеши в ответы не попадают.

Проверки

`mvn verify`: 11 тестов JUnit проверяют API, изоляцию заметок, SQLi, XSS, bcrypt и JWT. Запросы API также проверены через curl.

SpotBugs с FindSecBugs (SAST): 0 замечаний. SCA прерывается при находке с CVSS от 0 или ошибке сканера; все CVE может не обнаружить.

SpotBugs Report

Project Information

Project: Secure Notes API

SpotBugs version: 4.10.5

Code analyzed:

- /home/runner/work/information-security-lab-1/information-security-lab-1/target/classes

Metrics

213 lines of code analyzed, in 7 classes, in 1 packages.

Metric	Total	Density*
High Priority Warnings		0.00
Medium Priority Warnings		0.00
Total Warnings	**0**	**0.00**

(Defects per Thousand lines of non-commenting source statements)*

Рисунок 1 — HTML-отчет SpotBugs

OWASP Dependency-Check (SCA): 0 известных уязвимостей. NVD берется из зеркала разработчиков без API key. Проверяются и тестовые Java-зависимости; анализаторы .NET, JavaScript и OSS Index отключены.



DEPENDENCY-CHECK

Dependency-Check is an open source tool performing a best effort analysis of 3rd party dependencies; false positives and false negatives may exist in the analysis performed by the tool. Use of the tool and the reporting provided constitutes acceptance for use in an AS IS condition, and there are NO warranties, implied or otherwise, with regard to the analysis or its use. Any use of the tool and the reporting provided is at the user's risk. In no event shall the copyright holder or OWASP be held liable for any damages whatsoever arising out of or in connection with the use of this tool, the analysis performed, or the resulting report.

How to read the report | Suppressing false positives | Getting Help: github issues

Project: Secure Notes API

ru.itmo:secure-notes:1.0.0

Scan Information (show all):

- *dependency-check version*: 13.0.0
- *Report Generated On*: Mon, 2 Nov 2026 01:13:08 GMT
- *Dependencies Scanned*: 54 (33 unique)
- *Vulnerable Dependencies*: 0
- *Vulnerabilities Found*: 0
- *Vulnerabilities Suppressed*: 0
- ...

Summary

Summary of All Dependencies(click to show less)

Dependency	Vulnerability IDs	Package	Highest Severity	CVE Count	Confidence	Evidence Count
annotations-13.0.jar		pkg:maven/org.jetbrains/annotations@13.0		0		32
apiguardian-api-1.1.2.jar		pkg:maven/org.apiguardian/apiguardian-api@1.1.2		0		40
asm-9.10.1.jar		pkg:maven/org.ow2.asm/asm@9.10.1		0		54
asm-commons-9.10.1.jar		pkg:maven/org.ow2.asm/asm-commons@9.10.1		0		58
asm-tree-9.10.1.jar		pkg:maven/org.ow2.asm/asm-tree@9.10.1		0		58
bcrypt-0.10.2.jar		pkg:maven/at.favre.lib/bcrypt@0.10.2		0		23

Рисунок 2 — HTML-отчет OWASP Dependency-Check

GitHub Actions запускает сборку, тесты, SAST и SCA при `push` и `pull_request`. HTML-отчеты сохраняются в артефактах `spotbugs-report` и `dependency-check-report`.

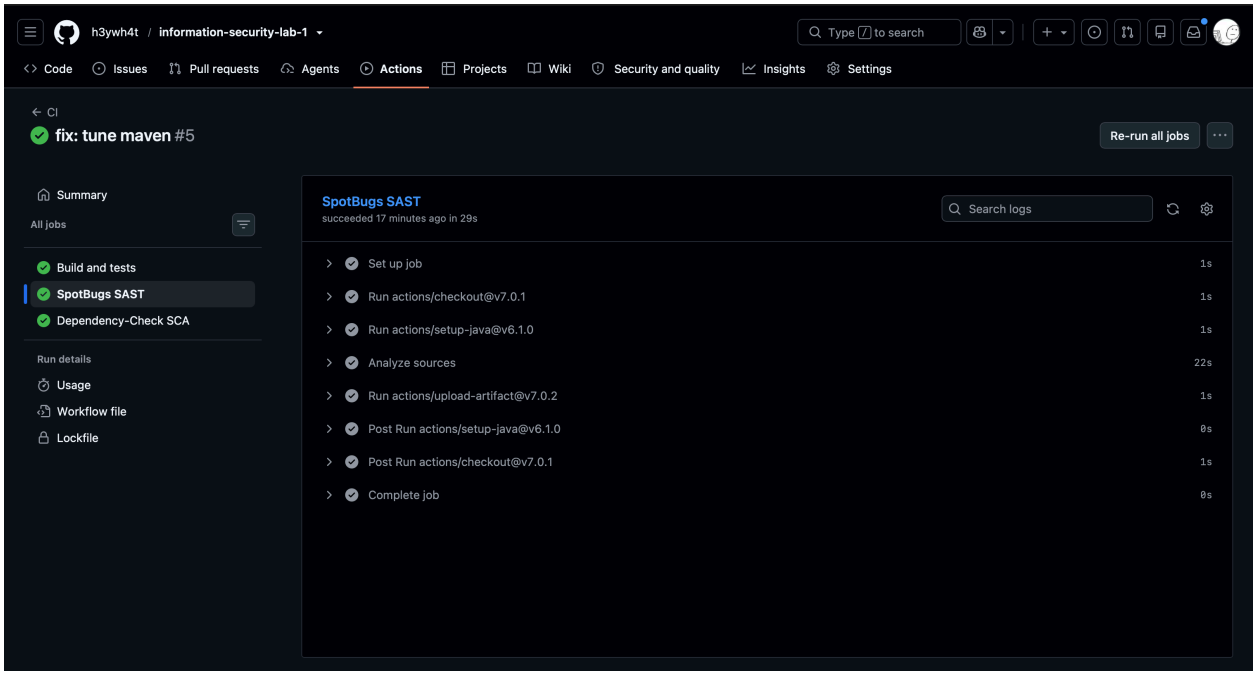


Рисунок 3 — Успешный GitHub Actions

Pipeline на скриншоте: запуск № 5. Последний успешный pipeline.